CWE AI Working Group
Meeting Minutes
February 14, 2025

Attendance

- Monika Akbar
- Chris Coffin
- Steve Christey Coley
- Erick Galinkin
- Martin Hodo
- Alec Summers
- Mike Simon
- Raymond Pompon
- Caroline Rocha
- Kevin Monette
- Lily Wong
- Dave Morse
- Avani Wildani
- Pieter van Wassenaer

Agenda:

- Meeting Introduction
- Status Updates
- Subgroup Updates
- Presentation: Kyle Norland (MITRE)
- Focus on New-Entry Submission

Meeting Notes:

Meeting Introduction: Steven and Erick coordinated the meeting, with Steven driving the slides and the agenda.

Status Updates

- **Subgroup Formation:** Steven and Erick discussed the formation of subgroups, emphasizing the need for leads, mailing lists, and focused subgroup meetings. They mentioned the need to set up separate mailing lists or other ways for discussion and to change the bi-weekly working group meetings to be more focused on subgroup meetings.
- **Introduction of New Members:** Steven welcomed new members Avani Wildani from Cloudflare and Chris Gorley from Cisco.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

    - **Avani Wildani Introduction:** Avani Wildani introduced herself as an AI researcher at Cloudflare.
    - **Chris Gourley Introduction:** Chris Gourley introduced himself as a member of Cisco's AI Red teaming group.
- **Multi-Chair Situation:** Steven reminded the WG that Erick Galinkin was Co-chair for the CWE AI WG, with Erick mentioning the need to follow up on the multi-chair situation, as multiple people had expressed an interest in co-chairing the CWE AI WG.
- **Upcoming CWE Release:** Steven reminded the group about the upcoming CWE release in late March 2025, emphasizing the importance of planning activities and prioritizing work. The latest possible date would be in the first few days of April.
- **Formation of Subgroups:** Steven and Erick discussed the formation of two subgroups: one for handling new entries to CWE and another for modifying existing entries. They emphasized the need for leads, mailing lists, and focused subgroup meetings.
    - **Need for Leads:** Steven mentioned the need to find leads for the subgroups and set up separate mailing lists or other ways for discussion. Erick committed to figuring out a system by the next meeting to manage the subgroup meetings effectively.
    - **Participation and Communication:** Steven and Erick encouraged members to participate in one or both subgroups and to use the mailing list for ad hoc communication. Erick highlighted the importance of sharing relevant information and examples to avoid adding more meetings.

Presentation: Kyle Norland (MITRE) Kyle Norland from MITRE shared his experience working on a project in AI software security, discussing the challenges of identifying weaknesses, case study production, and creating recommendations. He highlighted the differences in computational paradigms and the importance of securing AI systems.

- **Challenges Faced:** Kyle discussed the challenges faced in the project, particularly the differences in computational paradigms between traditional software and AI systems. He highlighted the difficulty in defining inputs, outputs, and intentionality in AI systems.
- **Weaknesses Identified:** Kyle mentioned that many weaknesses were found in the process of creating, curating, and protecting data fed into AI models. Additionally, weaknesses were identified in the interaction between deployed models and users, including vulnerabilities from external sources.
- **Case Studies:** Kyle shared that many case studies revealed conventional cybersecurity weaknesses in AI systems, often due to rushed development and

inadequate cybersecurity processes. He emphasized the hybrid nature of securing AI systems, combining traditional and AI-specific challenges.

  - **Recommendations:** Kyle sought input on the most useful way to package their findings, whether through further discussion in the group, proposals of weakness categories, or other methods. He expressed a desire to continue participating in the group and discussing AI-related topics.

- **Discussion on Kyle's Presentation:** Steven, Erick, and Kyle discussed the challenges of defining weaknesses in AI systems, focusing on the differences between traditional software and AI systems, the importance of data governance, and the potential biases in AI models.

  - **Defining Weaknesses:** Steven, Erick, and Kyle discussed the challenges of defining weaknesses in AI systems, emphasizing the differences between traditional software and AI systems. They highlighted the importance of focusing on behaviors and mistakes that cause poor behaviors in AI systems.

  - **Data Governance:** Erick stressed the importance of data governance, data collection, and data cleaning in AI systems. He pointed out that training models on crummy or biased data can lead to vulnerabilities, like traditional cybersecurity issues.

  - **Bias in AI Models:** Caroline and Erick discussed the potential biases in AI models, noting that biases in data can lead to biased AI systems. They emphasized the need for security controls and validation to protect data and ensure the integrity of AI models.

  - **Human Factors:** Steven mentioned the difficulty in distinguishing between human processes and system behaviors when defining weaknesses. He highlighted the importance of understanding the result of human actions that lead to insecure behavior in AI systems.

  - **Defining AI Weaknesses**: Bob Heinemann suggested anchoring the discussion on the CWE definition of a weakness, which refers to a condition that, under certain circumstances, could contribute to vulnerabilities. Steve reinforced the importance of focusing on root mistakes, not just how attackers exploit them.

Focus on New-Entry Submission: The group discussed Lily Wong's submission, **"LLM Bad Practices: Improper Tuning of Model Control Parameters" – ES2406-9e5fcf10**, emphasizing the need to refine the description, providing specific examples, and focus on the mistakes developers make that lead to insecure behavior.

- **Parameter Settings:** Steven highlighted the importance of tying together the concepts of temperatures and parameter settings with their security implications. He suggested focusing on how improper tuning can lead to privacy leaks, denial of service, or other security issues.
- Avani remarked that the simplest "AI" for text generation is simply outputting the most popular word in a sentence and questioned whether restricting generation to specific model architectures is necessary.
- Erick shared links to papers he co-authored, discussing "package hallucination" and hyperparameter settings affecting jailbreak success rates.
- **Examples and Clarifications:** Lily suggested providing specific examples to illustrate the effects of improper tuning, such as package hallucination. She emphasized that examples could help clarify the general framing of the weakness for those unfamiliar with the domain.
- **Generalization and Specificity:** Erick proposed generalizing the description to cover various text generation models and specifying common hyperparameters like top P, top K, and temperature. He suggested adding clarifying language around terms like hallucination to make the description more accessible.

Action Items:

- **Subgroup Formation:** Set up separate mailing lists or other communication methods for the new subgroups. (Erick)

- **Subgroup Leads:** Identify and assign leads for the new subgroups focused on new entries and modifications to existing entries. (Erick)

- **Meeting Coordination:** Figure out a system for alternating subgroup meetings and update the meeting titles accordingly. (Erick)

- **Improper Tuning Submission:** Refine the description of the improper tuning of model control parameters submission to be more general and specific where needed, and add clarifying language around key terms. (Erick)

- **CWE Development Repository Access:** Provide GitHub usernames to gain access to the CWE development repository for focused discussion on the improper tuning submission. (All interested members)